

Structural Invariants, Attack-Graph Mathematics, and an Autonomous Red-Team Platform

VALEN Project

Working draft v0.5

Two theses, one typed IR

Defensive thesis (measured)

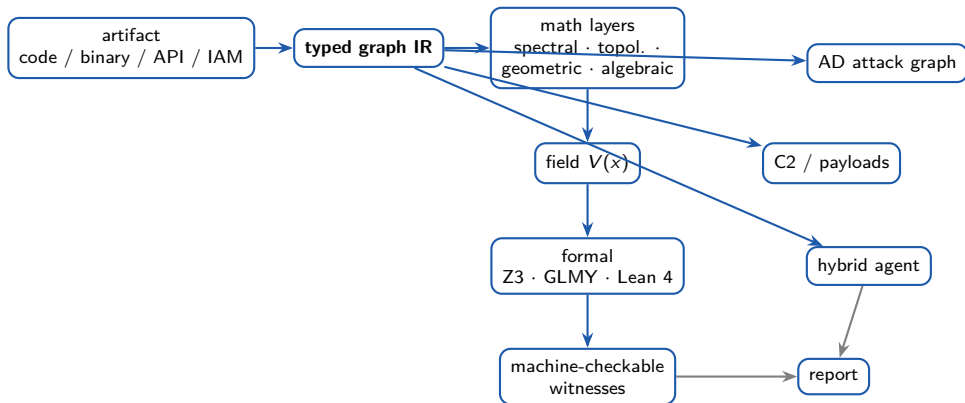
- Structural invariants (spectral, homology, curvature) add *nothing* over taint for injection prioritization.
- But they are the *only* signal for authorization (BOLA/IDOR), destructive state cycles, and trust topology.

Offensive thesis

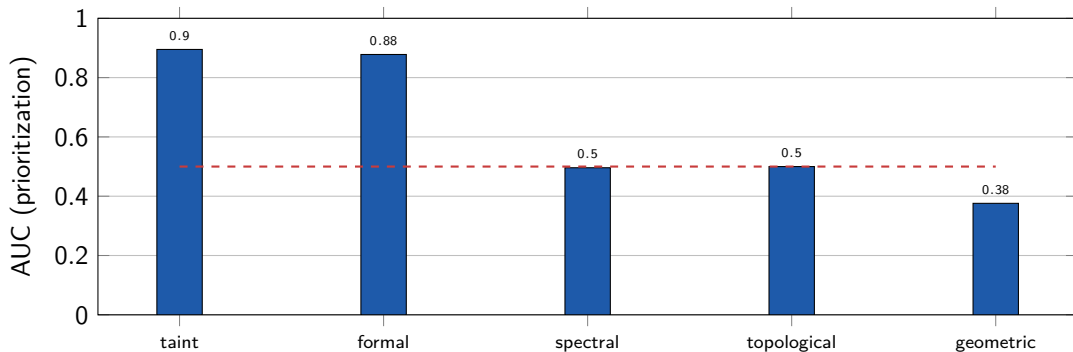
- An autonomous red-team platform over the *same* graph.
- Differentiator: *quantitative attack-graph mathematics*, not scripting.

One deterministic typed graph IR $\rightarrow$ verifier $\cdot$ planner $\cdot$ platform.

System architecture



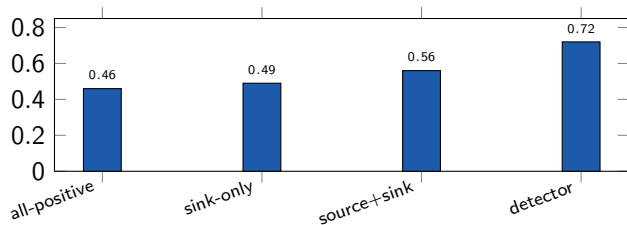
The boundary result (injection SAST)



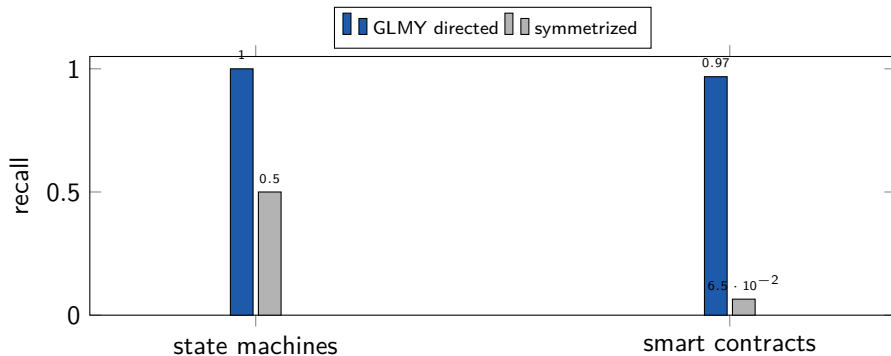
- OWASP Benchmark 1.2 (2740 cases): taint MRR 0.894 beats fused field 0.872 ($p = 5 \times 10^{-5}$).
- Spectral/topological at chance; curvature below chance. *A falsifiable negative result.*

Authorization, mechanized and operational

- Privilege-level function $F : V \rightarrow \mathbb{N}$; auth edge iff $F(u) < F(v)$; no_auth_bounded mechanized in Lean 4.
- Structural BOLA/IDOR detector: recall 1.0 / precision 0.72 / F1 0.837 where taint scores 0.
- Z3 ownership witness $\text{SAT}(\text{owner}(id) \neq \text{session})$: separates object-level authorization from mere authentication.
- Real data (crAPI, 9 endpoints): recall 1.0 / precision 0.90; the missing-auth check scores 0 because BOLA is authenticated.

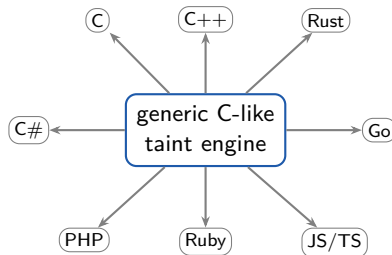


Directed path homology (GLMY)



- Symmetrization collapses the directed 2-cycle: recall $1.0 \rightarrow 0.5$ (state), $0.97 \rightarrow 0.065$ (contracts).
- Returns the concrete β_1 generator as evidence.

Multi-language SAST



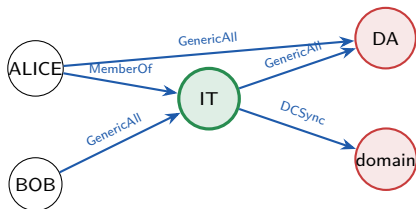
- 9 grammars, 1 engine; per-language source/sink/sanitizer profiles.
- Canonical categories.py: severity + CWE + OWASP + CVSS 3.1/4.0 + MITRE per finding.

The red-team platform



- Multi-user *team server*: roles (viewer/operator/admin), PBKDF2 sessions, RBAC, SSE live collaboration, SQLite persistence.
- Recon → AD → C2/payloads → creds (Kerberoast/PCFG) → phishing/exfil → report.
- *Authorization-first*: scope allow-list, -allow-exec, operator approval.

Attack-graph mathematics



- **Min-cut (Menger)**: chokepoints (BOB→IT, min-cut 1).
- **Min-cost flow**: cheapest disjoint plans. **Hitting probability**: exact $(I - Q)^{-1}R$.
- **Z3 synthesis**: minimal-cost ordered exploit plans + AND-preconditions.
- **PCFG**: probabilistic password prior from a cracked corpus.

Autonomous pentest (crAPI)

18/18

- BOLA/BFLA, mass assignment, SSRF, NoSQL/SQLi, JWT, LLM prompt injection.
- BOLA recall 1.0 / precision 0.90.

Results at a glance

boundary	taint 0.894 vs field 0.872
BOLA/IDOR	1.0 / 0.90 (crAPI)
GLMY	0.97 vs 0.065 recall
arbitration	agreement 0.974
languages	9, 1 engine
tests	383 green

Formal results (with proofs)

Theorem (No privilege escalation)

An ungated path satisfies $F(v_k) \leq F(v_0)$ (mechanized in Lean 4).

Theorem (Menger, vertex form)

Max internally vertex-disjoint S - T paths = min vertex cut (chokepoints).

Theorem (Synthesis optimality)

The Z3-Optimize model is a feasible plan and minimal-cost among length $\leq k$; AND-preconditions model multi-requirement actions.

Theorem (PCFG monotonicity)

Best-first expansion enumerates guesses in non-increasing probability, no duplicates.

- **Defensive:** structural invariants verify authorization, state, and trust — not injection prioritization (measured boundary).
- **Offensive:** a red-team platform whose differentiator is *quantitative attack-graph mathematics*.
- **One typed IR** joins both; every result carries a machine-checkable witness.
- Installable, tested, documented; authorization-first by design.